SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A1-Threat Intelligence Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
REg.No	192411156	**Name**	K. Hema Sree
Faculty	Dr.V.Parthipan	**Slot**	A

Instructions: Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.

Code of Conduct:

I , Keerthipati Hema Sree, 192411156 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of Student

k. Hema

Questions

Q1. Malware [5 Marks]

Define malware and explain any four types of malware (virus, worm, trojan, ransomware, spyware). For each type, state how it spreads and one impact on the victim.

Q2. Phishing [5 Marks]

Describe how a phishing attack is carried out. Differentiate between spear phishing, whaling and vishing, and list three measures an organisation can adopt to reduce phishing risk.

Q3. DoS and DDoS [5 Marks]

Distinguish between a Denial of Service (DoS) attack and a Distributed Denial of Service (DDoS) attack. Explain the working of a SYN flood and outline two mitigation techniques.

Q4. Man-in-the-Middle Attacks [5 Marks]

What is a Man-in-the-Middle (MITM) attack? Explain two techniques used to carry it out (for example ARP poisoning, rogue Wi-Fi access point, SSL stripping) and state how encryption helps defend against it.

Q5. Spoofing and Sniffing [5 Marks]

Compare spoofing and sniffing. Explain IP spoofing and ARP spoofing with an example each, and describe how packet sniffers such as Wireshark can be used both maliciously and legitimately.

Q6. Vulnerability Assessment [5 Marks]

Explain the vulnerability assessment process. Describe its main phases, and differentiate between vulnerability assessment and penetration testing. Name two commonly used scanning tools.

Q7. Vulnerability Scoring [5 Marks]

What are CVE and CVSS? Explain how CVSS scores help in prioritising vulnerabilities and why a high CVSS score alone may not decide the order of patching.

Q8. Threat Data Sources and OSINT [5 Marks]

Discuss the main sources of threat data (internal, external, open-source and commercial). Define Open-Source Intelligence (OSINT) and describe three OSINT sources or tools used in threat intelligence gathering.

Q9. Indicators of Compromise (IoCs) [5 Marks]

What are Indicators of Compromise (IoCs)? Classify them into network-based, host-based and file-based indicators with two examples of each, and explain how a security team uses IoCs during incident response.

Q10. Threat Feeds [5 Marks]

Explain what a threat intelligence feed is. Describe the common feed formats and sharing standards (STIX/TAXII), list two advantages and two limitations of using threat feeds, and name two example feeds.

Answers :

Q1. Malware

Definition: Malware (malicious software) is any program or code intentionally designed to damage, disrupt, steal data from, or gain unauthorised access to a computer system, network or user.

Type	How it spreads	Impact on victim
Virus	Attaches itself to a legitimate file or program and spreads when the host file is executed or shared (USB drives, email attachments, downloads).	Corrupts or deletes files and slows the system.
Worm	Self-replicates without a host file or user action, exploiting network vulnerabilities and weak services, or spreading via email.	Consumes bandwidth and resources, causing network congestion or outages.
Trojan	Disguised as useful software (cracked apps, fake installers, attachments); the user installs it voluntarily.	Opens a backdoor, letting attackers control the system or install more malware.

Type	How it spreads	Impact on victim
Ransomware	Phishing emails, malicious downloads, exposed remote-access services, unpatched systems.	Encrypts files and demands payment, causing data loss and business downtime.
Spyware (bonus)	Bundled with free software or drive-by downloads.	Secretly records keystrokes and browsing, leading to credential and identity theft.

Q2. Phishing

How an attack is carried out:

1. **Reconnaissance:** the attacker picks targets and gathers information such as email addresses and the organisation's brands.
2. **Bait creation:** a fake email, SMS or website is built that imitates a trusted entity (bank, employer, courier).
3. **Delivery:** the message is sent with an urgent pretext ("account suspended", "invoice attached").
4. **Victim action:** the user clicks a link, opens an attachment or enters credentials on a fake page.
5. **Exploitation:** stolen credentials or data are used for fraud, account takeover or further intrusion.

Differences:

Attack	Target	Method
Spear phishing	A specific individual or small group	Personalised email using details about the victim (name, role, colleagues).
Whaling	Senior executives (CEO, CFO)	Highly tailored, often about legal, financial or board matters, aimed at authorising payments or revealing sensitive data.
Vishing	Any individual	Voice phishing by phone call or voicemail, impersonating a bank or IT support to extract OTPs or details.

Three organisational measures:

- Regular security awareness training and simulated phishing exercises.
- Email filtering (SPF, DKIM, DMARC, spam and attachment sandboxing) and web/URL filtering.
- Multi-factor authentication, plus a simple process for reporting suspicious emails.

Q3. DoS and DDoS

Basis	DoS	DDoS
Source	A single machine/connection	Many compromised machines (botnet)
Scale	Limited traffic volume	Very large volume, can saturate big targets
Detection/blocking	Easy: block one IP	Hard: traffic comes from thousands of IPs
Traceability	Attacker easier to trace	Attacker hidden behind the botnet

SYN flood: TCP connections use a three-way handshake (SYN → SYN-ACK → ACK). In a SYN flood, the attacker sends a large number of SYN packets, usually with spoofed source IPs. The server replies with SYN-ACK and reserves a half-open connection entry in its backlog queue, but the final ACK never arrives. The queue fills, and legitimate users can no longer connect.

Mitigation (any two):

- **SYN cookies:** the server doesn't allocate resources until the final ACK validates the connection.
- **Rate limiting / firewall / IPS filtering:** limit SYN packets per source and drop suspicious traffic.
- Reducing half-open timeout and increasing backlog size, or using a CDN or DDoS scrubbing service.

Q4. Man-in-the-Middle (MITM) Attacks

Definition: In a MITM attack, an attacker secretly positions themselves between two communicating parties, intercepting and possibly altering the messages while both believe they are talking directly to each other.

Two techniques:

1. **ARP poisoning:** On a LAN, the attacker sends forged ARP replies linking their MAC address to the gateway's IP (and vice versa). Victims' traffic is then routed through the attacker's machine.
2. **Rogue Wi-Fi access point:** The attacker sets up a hotspot with a legitimate-looking name (e.g. "Free_Airport_WiFi"). Users who connect have all their traffic pass through the attacker's device.
3. *(Also common)* **SSL stripping:** the attacker downgrades an HTTPS connection to HTTP so the victim's traffic is visible in plain text.

How encryption helps: Encryption (TLS/HTTPS, VPNs, WPA2/WPA3) makes intercepted data unreadable without the keys. Certificate validation lets the client authenticate the server, so an impersonator is detected. HSTS stops downgrade attacks like SSL stripping. Even if the traffic is captured, confidentiality and integrity are preserved.

Q5. Spoofing and Sniffing

Basis	Spoofing	Sniffing
Nature	**Active:** forging identity or data	**Passive:** capturing/monitoring traffic
Goal	Impersonate a trusted device or user	Read or collect data in transit
Effect on network	Injects false packets or information	Usually undetectable, doesn't alter traffic

IP spoofing: The attacker forges the source IP in packet headers to impersonate another host or hide their identity. *Example:* In a DDoS reflection attack, the attacker sends requests with the victim's IP as source, so replies flood the victim.

ARP spoofing: The attacker sends fake ARP messages to associate their MAC with another host's IP on the LAN. *Example:* An attacker poses as the default gateway, so all hosts send traffic to them, enabling eavesdropping or MITM.

Packet sniffers (e.g. Wireshark): A sniffer captures and analyses packets passing through a network interface.

- *Malicious use:* capturing unencrypted passwords, session cookies and sensitive data on shared or insecure networks.
- *Legitimate use:* network troubleshooting, performance analysis, protocol debugging, detecting intrusions and malware traffic, and security training.

Q6. Vulnerability Assessment

Definition: Vulnerability assessment (VA) is the systematic process of identifying, classifying and prioritising security weaknesses in systems, networks and applications.

Main phases:

1. **Planning and scoping:** define goals, assets and rules.
2. **Asset discovery:** identify hosts, services, OS and applications.
3. **Vulnerability scanning:** run automated scans against the assets.
4. **Analysis and prioritisation:** verify findings, remove false positives, and rank risks.
5. **Reporting:** document findings with severity and recommendations.
6. **Remediation and rescan:** patch or mitigate, then verify the fix.

VA vs Penetration Testing:

Basis	Vulnerability Assessment	Penetration Testing
Objective	Find and list weaknesses	Exploit weaknesses to prove real impact
Approach	Mostly automated	Mostly manual, skill-driven
Depth	Broad	Deep and targeted

Basis	Vulnerability Assessment	Penetration Testing
Frequency	Regular/continuous	Periodic (e.g. annually)
Output	List of vulnerabilities with ratings	Proof of compromise and attack paths

Scanning tools: Nessus and OpenVAS (Qualys and Nmap are also used).

Q7. Vulnerability Scoring

- **CVE (Common Vulnerabilities and Exposures):** A standard list of publicly disclosed vulnerabilities, each with a unique ID (e.g. CVE-2021-44228), allowing everyone to refer to the same flaw consistently.
- **CVSS (Common Vulnerability Scoring System):** An open framework that rates the severity of a vulnerability on a **0–10** scale, based on Base, Temporal and Environmental metrics. Ratings: Low (0.1–3.9), Medium (4.0–6.9), High (7.0–8.9), Critical (9.0–10.0).

Use in prioritisation: CVSS gives a common, objective measure so teams can sort thousands of findings and fix the most severe ones first, and it helps set patching deadlines (SLAs).

Why a high score alone isn't enough:

- The vulnerability may not be exploitable in practice or have no known exploit in the wild.
- The affected asset may be non-critical or isolated, while a medium-score flaw on a critical internet-facing server may matter more.
- Compensating controls (firewall, WAF, segmentation) may reduce the risk.
- Patch availability and downtime constraints affect scheduling.

So organisations combine CVSS with asset value, exploit intelligence (e.g. CISA KEV, EPSS) and business context.

Q8. Threat Data Sources and OSINT

Sources of threat data:

- **Internal:** logs from firewalls, IDS/IPS, SIEM, endpoints, DNS and email gateways, and past incident reports. They are highly relevant to the organisation.
- **External:** information from outside, such as government/CERT advisories, industry sharing groups (ISACs), and vendor and partner reports.
- **Open-source:** freely available data such as public blogs, forums, vulnerability databases and free feeds.
- **Commercial:** paid feeds and platforms (e.g. Recorded Future, CrowdStrike, Mandiant) offering curated, enriched and often more timely intelligence.

OSINT: Open-Source Intelligence is intelligence collected and analysed from publicly available information to support security decisions, without breaking into any system.

Three OSINT sources/tools:

1. **Shodan:** a search engine for internet-connected devices, used to find exposed services and misconfigurations.
2. **VirusTotal:** analyses files, URLs, domains and IPs against many antivirus engines and reputation sources.
3. **Maltego** (or WHOIS/Have I Been Pwned/social media/paste sites): maps relationships between domains, IPs, people and infrastructure, and finds leaked credentials.

Q9. Indicators of Compromise (IoCs)

Definition: IoCs are pieces of forensic evidence or artefacts that suggest a system or network has been breached or is under attack.

Category	Examples
Network-based	Connections to known malicious IPs/domains (C2 servers); unusual outbound traffic volume or beaconing; abnormal DNS requests
Host-based	New or unknown processes and services; suspicious registry changes or startup entries; unexpected admin accounts or login times
File-based	Malicious file hashes (MD5/SHA-256); unusual file names or locations; malicious email attachments or modified system files

Use during incident response:

- **Detection:** feed IoCs into SIEM, IDS and EDR tools to raise alerts.
- **Scoping:** search logs and endpoints to find all affected systems.
- **Containment:** block malicious IPs, domains and hashes, and isolate infected hosts.
- **Eradication and recovery:** confirm that all traces are removed.
- **Lessons learned and sharing:** update defences and share IoCs with partners.

Q10. Threat Feeds

Definition: A threat intelligence feed is a continuously updated stream of data about threats, such as malicious IPs, domains, URLs, file hashes and attacker tactics, that security tools consume to detect and block attacks.

Common formats: CSV, plain-text blocklists, JSON, XML, OpenIOC, MISP format, and **STIX**.

Sharing standards:

- **STIX (Structured Threat Information eXpression):** a standard language for describing threat information (indicators, malware, actors, campaigns).
- **TAXII (Trusted Automated eXchange of Intelligence Information):** the transport protocol that exchanges STIX data automatically between systems over HTTPS.

Advantages:

- Provide timely, broad visibility into emerging threats beyond an organisation's own data.

- Can be automated into SIEM, firewalls and EDR for faster detection and blocking.

Limitations:

- Can generate false positives and noise, and indicators go stale quickly (IPs and domains change).
- Often lack organisational context, and quality varies, so they need validation and analyst effort. Commercial feeds also add cost.

Example feeds: AlienVault OTX and abuse.ch (also CISA Automated Indicator Sharing, MISP communities).

Marking Scheme (for evaluator)

Q.No	Expected points and mark distribution (total 5)
1	Definition (1); four types with spread method and impact (4 x 1 = 4).
2	Attack flow (1.5); three variants differentiated (1.5); three countermeasures (2).
3	DoS vs DDoS (1.5); SYN flood working (1.5); two mitigations such as rate limiting, SYN cookies, CDN/scrubbing, blackhole routing (2).
4	Definition and interception concept (1); two techniques (2); defences such as TLS, HSTS, certificate validation, VPN (2).
5	Comparison (1); IP and ARP spoofing with examples (2); sniffer dual use (1.5); one countermeasure (0.5).
6	Phases: asset discovery, scanning, analysis and prioritisation, reporting, remediation (2); VA vs pen test (2); two tools such as Nessus, OpenVAS, Qualys (1).
7	CVE meaning (1); CVSS meaning and severity ratings (1.5); role in prioritisation (1.5); context factors such as exploitability and asset criticality (1).
8	Threat data source categories (2); OSINT definition (1); three OSINT sources or tools such as Shodan, VirusTotal, WHOIS, social media, dark web monitoring (2).
9	Definition (1); classification with examples (3); use in detection and response (1).
10	Definition (1); STIX/TAXII or similar formats (1.5); two advantages and two limitations (2); two example feeds such as AlienVault OTX, MISP, abuse.ch (0.5).